AI-conducted targeted security review by Claude Fable 5.1 (claude-fable-5-1), Anthropic's model, completed 7 November 2026 for Blast. Reviewed interest-protocol/blast-v2-contracts PR #225, merged as af0765dab18de741b130c52831c859717134f2c1; its sui/ tree is identical to the deployed commit 86ee8cf9. Rendered from the Markdown source kept in the Blast workspace; relative links were flattened.

Targeted security audit: PR #225 at `af0765da`

Independent review of `interest-protocol/blast-v2-contracts` PR #225, merged 6 November 2026 as `af0765dab18de741b130c52831c859717134f2c1`. Reviewed 7 November 2026 by the Fable audit session from a detached worktree at that commit (`worktrees/contracts-pr225-audit-20261107`). Evidence logs: outputs/verification/2026-11-07-pr225-targeted-audit-af0765d-fable.

Verdict

No release blocker was found inside PR #225's scope. The `AutoLpAdmin` guard and the keeper price bounds are enforced in the only code path that can move the vault's auto-LP balances, no public or package function bypasses either, and the pool consume-and-re-share pattern behaves as ADR 0139 describes on the pinned Sui runtime. The launchpad's new seed-price check is applied to exactly the amounts the later migration hands off. The `TxContext` additions are inert reservations.

Two informational observations are recorded (F-1, F-2) and one operational gap that live verification must close before a keeper is enabled (F-3). GiveRep's remediation review is consistent with the code; this review adds F-1, which that report does not mention.

Scope and method

- **Baseline and target.** `git diff af0765da^ af0765da -- sui/` against parent `9f9bca14`. The `sui/` tree at `af0765da` is byte-identical to the deployment record's pinned commit `86ee8cf9` (`git diff --stat af0765da 86ee8cf9 -- sui/` is empty), so the deployed Move source is the source reviewed here. Deployment record: `deployments/sui/mainnet/2026-11-06-canonical-launch-stack.json` at `b447aa81`.
- **Order of work.** Code first: the production diff, then every caller and callee of the changed functions across `blast_core`, `blast_admin`, `blast_vault`, `blast_migrators`, `blast_fun` and `blast_presale`, then the venue interfaces and the Sui runtime natives the design relies on, then the repository gates. The GiveRep report was read only after the conclusions below were formed.
- **Toolchain.** `sui 1.77.2-51d177ad7d65` (the record's toolchain), Move tests with the instruction limits GiveRep documents, the native PTB harness against the committed mainnet bytecode snapshot, and the repository's structural gates.

What changed on chain

Production Move source (the only files that affect published bytecode):

File	Change
`sui/core/sources/blast_domain.move`	New role witness `AutoLpAdmin()`

File	Change
`sui/migrators/sources/venues/cetus.move`	`compound_auto_lp` becomes private `entry`; takes `&ACL`, `&AdminCap`, the `Pool` by value, inclusive `min_sqrt_price`/`max_sqrt_price`; re-shares the pool; `migrate` forwards `ctx` to `vault::new`
`sui/migrators/sources/venues/bluefin.move`	Same as Cetus; `prepare` gains a trailing `&mut TxContext`
`sui/migrators/sources/lib/errors.move`	New `EInvalidAutoLpPrice = 5`
`sui/launchpad/sources/launch/launch.move`	`finalize` asserts `is_seedable_price(sqrt_price_x64(lp_meme, lp_quote, true))` before `ticket.destroy`; `finalize`, `share`, `settle_opening_round` gain a trailing `&mut TxContext`
`sui/launchpad/sources/lib/errors.move`	Doc of `EInvalidGraduationTarget` widened to the unseedable price
`sui/presale/sources/blast_presale.move`	`share`, `settle`, `cancel_unlaunched` gain a trailing `&mut TxContext`
`sui/vault/sources/vault.move`	`new` gains a trailing `&mut TxContext`; module doc now says "no exposed withdrawal path" instead of "permanent"
`sui/vault/sources/holder_rewards.move`	`close_round` gains a trailing `&mut TxContext`

Not on chain (reviewed separately): `sui/launchpad/ptb_tests/tests/venue_fork.rs` (new `compounding_guards`, compounding moved out of the collection PTB, `AutoLpAdmin` added to the fixture roles); Move test updates in launchpad, presale, vault and migrators (context arguments, the new error count, one new launchpad rejection test, address-dependent `creator_authority` signature fixtures); `sui/presale_testkit/sources/sale_tokens.move` deleted (obsolete raw-cap constructors); the migrators and launchpad `check_source_boundaries.sh` pins; `scripts/check_move_errors.py` native oracle for the new error; ADR 0139, an ADR 0137 amendment, `docs/architecture.md`, `docs/llms/*` and the generated `llms*` files; `sui/migrators/DEPENDENCIES.md`.

Auto-LP compounding

Authorization

`compound_auto_lp` (Cetus `cetus.move:280-310`, Bluefin `bluefin.move:224-253`) calls `acl.sign_in<AutoLpAdmin>(admin_cap)` immediately after the version check. `blast_acl::sign_in` (`blast_acl.move:208-218`) aborts unless the cap's ID is a live administrator and that administrator's role set contains `AutoLpAdmin` by defining ID. Revocation of the role or the administrator takes effect on the next call. The witness is dropped; nothing else consumes it, so no other function can be reached with it.

Bypass analysis

The balances at risk are `Vault.auto_lp_meme` and `Vault.auto_lp_quote`. The only functions that withdraw them are `vault::take_auto_lp` and the paired `vault::keep_auto_lp` (`vault.move:353-407`). Both are `public fun` but take `_: &Venue` and call `assert_position<Venue>`, which requires the caller's `Venue` type to hold the vault's migration position key. `Venue` is `public struct Venue() has drop` in each venue module; Move permits construction only inside the defining module, so only `blast_migrators::cetus` and `blast_migrators::bluefin` can call them, and only for vaults they

created. Inside those modules, `take_auto_lp` is reached from exactly one function each (`compound`, Cetus `cetus.move:420-441`, Bluefin `bluefin.move:375-402`), and `compound` is called only from `compound_auto_lp`. `auto_lp_position_mut`, `attach_auto_lp_position` and `position_mut` are gated the same way and are reached only from `compound`/`add_liquidity` and from fee collection, which never adds liquidity. No `public`, `public(package)` or other `entry` function in the seven packages reaches the add path. The migrators source gate pins both entries as the package's only entry functions, their complete signatures, and the exact body order (`check_source_boundaries.sh:136,157,163,525,643`), so a future edit cannot silently reopen the path.

Composition: a PTB cannot pass a hot potato or Move-call result into a private entry, and the pool input is consumed by value, so no later command in the same PTB can use it (the native test proves `ArgumentWithoutValue` on a subsequent getter). A swap earlier in the same PTB, or in an earlier transaction, is not prevented; the price bounds are the guard for that, as ADR 0139 states.

Price bounds constrain the actual add

Both entries validate `min > 0 && min <= max`, match `self.pool_id()` to the pool object, read `pool.current_sqrt_price()` and assert `min <= price <= max` before `take_auto_lp`. The pool is held by value for the rest of the function, so nothing can move its price between the check and the venue's `add_liquidity_*` call; the add executes at the price that was checked. Both venues' `fixed_side` logic chooses the side whose counterpart the other balance covers, and the residue is returned through `keep_auto_lp`, which asserts `returned <= taken` and emits `AutoLiquidityAdded` with the measured delta. Fee and LP accounting is therefore venue-measured and conserved; nothing in #225 changed those paths.

Residual, accepted in ADR 0139: a keeper with permissive bounds, or a compromised keeper key, can reinvest at a manipulated price. Exposure is bounded by the waiting auto-LP balances of one vault per call and by the keeper's slippage policy; migration principal and the burned Cetus position are not reachable. A front-runner who pushes the price outside the bounds only makes the call abort.

Pool consume and re-share

`transfer::public_share_object(pool)` is the last statement of each entry. Both venue `Pool` types have `key, store` (Cetus interface `pool.move:8`, Bluefin `pool.move:28`). The pinned Sui runtime `51d177ad` accepts re-sharing a previously shared object (`sui-move-natives/src/transfer.rs:332-334`, `TransferResult::SameOwner` is `ok`), confirming ADR 0139's S1. The native suite exercises repeated compounding after re-sharing on both venues.

Abort behaviour

Any abort (bad bounds, revoked role, wrong pool, venue refusal of the add) rolls back the whole transaction; the pool stays shared and the vault balances are untouched. Fee collection (`collect_fees`, `settle_and_apply_fee_split`) is permissionless and does not call `compound`, so compounding failures never block collection, owner claims, payouts or holder rewards.

Launchpad seed-price validation

`launch::finalize` (`launch.move:265-276`) now computes `lp_quote` from `apportion_quote(graduation_target)` and `lp_meme` from `apportion_meme(atomic_supply)` on the plan after `add_protocol`, and requires `is_seedable_price(sqrt_price_x64(lp_meme, lp_quote, true))` before `ticket.destroy` fixes the supply and before `derived_object::claim` mutates the

registry. `launch::migrate` (`launch.move:850-863`) apportions the same stored plan over `atomic_supply` and `real_quote_reserve`; `curve::cap_buy_quote_input` caps the crossing buy so the reserve equals the target exactly at graduation, so the checked price is the price the venue will seed. The bounds `[2·MIN, MAX/2]` are reciprocal (`MIN·MAX = 2^128` to within 1e-10, checked numerically), so the check holds for either Cetus coin order, and the factor-two sqrt margin (about 13,860 ticks) covers the inward tick alignment at the largest allowed spacing (400). Presale creation already applied the same preflight; nothing there changed.

Transaction-context reservations

Eight functions gain a trailing unused `&mut TxContext`. Sui injects it for PTB calls and direct Move callers forward theirs. This adds no authorization and no isolation; its purpose is to make a future compatible upgrade possible without a signature change, as the ADR 0137 amendment records. Creation, migration, claim and settlement paths are otherwise unchanged; all affected Move suites and the launchpad/presale structural gates pass with the new signatures.

Findings

F-1 Informational: compounding is not covered by the vault's admin pause bit

- **Location.** `sui/vault/sources/vault.move:353-371` (`take_auto_lp`); entries at `cetus.move:280` and `bluefin.move:224`.
- **Contract.** The vault defines one pause bit, `admin_pause_bit`, and applies it to its administrator-driven economic operations: `take_buyback_quote` (`vault.move:419`), `schedule_protocol_bps`/`apply_protocol_bps` (`vault.move:534,547`) and holder-reward scheduling, publication and funding. `package_admin::pause` lets a `PauseAdmin<BLAST_VAULT_PACKAGE>` set it at once. #225 turned compounding into an administrator-driven economic operation of the same kind but did not add the check, so a vault pause stops buybacks and reward publication while a keeper can keep adding liquidity.
- **Prerequisites.** A live `AutoLpAdmin` keeper and an incident in which the pause admin pauses the vault package (for example, a suspected keeper-key compromise or a venue incident).
- **Path.** Pause bit set; keeper (or an attacker holding its cap) calls `compound_auto_lp` with bounds of its choosing; the add proceeds. Impact is the same bounded auto-LP exposure as the accepted keeper trust, and `blast_acl::revoke_role` is an equivalent immediate stop, so this is an inconsistency in the emergency-control surface rather than a vulnerability.
- **Remediation.** Add `package_version.assert_not_paused(constants::admin_pause_bit!())` as the first guard of `take_auto_lp` (mirroring `take_buyback_quote`) and pin it in the vault source gate; alternatively record in ADR 0139 that compounding is stopped by role revocation only.
- **Owner decision (7 November 2026).** Record in ADR only, no code change: contracts PR #236 amends ADR 0139 so revoking `AutoLpAdmin` is the documented stop for compounding.
- **Regression test.** Vault Move test: set the admin pause bit on the fixture `PackageVersion`, call `take_auto_lp` with the fixture venue, expect `blast_admin::errors::EPaused` at `blast_vault::vault`. Native: pause the vault package through `package_admin::pause`, run `compound_auto_lp` with valid bounds, assert rollback with that abort.

F-2 Informational: the launchpad reuses `EInvalidGraduationTarget` for an unseedable allocation price

- **Location.** `sui/launchpad/sources/launch/launch.move:272-275`; `sui/launchpad/sources/lib/errors.move:54-56`.
- **Observation.** The presale aborts the identical preflight with a dedicated `EUnseedablePrice`. The launchpad's price can be unseedable because of the allocation shares or the coin's decimals, not only the target, so the abort name misdirects a creator or integrator who reads it. The comment was widened to say so, and `llms/launchpad.txt` documents it, so this is a diagnostic clarity note, not a defect. Reusing the code avoids a new error number in the still-unpublished package; if a dedicated code is preferred, add it before publication is final.
- **Regression test.** Already present: `unseedable_migration_price_is_rejected_at_finalization` pins the current code and location.

F-3 Operational gap, live verification: no `AutoLpAdmin` is granted on mainnet and no keeper exists

- **Evidence.** The deployment record grants exactly two live `AdminCap`s with `ListingAdmin`, `FeeAdmin`, `TreasuryAdmin`, `ClaimSignerAdmin`, three `UnpauseAdmin<...>` and `VenueAdmin`. `AutoLpAdmin`, `BuybackAdmin`, `CreatorAdmin`, `RewardsAdmin` and every `PauseAdmin<...>` are absent. ADR 0139 also requires the worker's transaction builder to be updated for the new ABI (`ACL`, owned cap, by-value pool, bounds in pool coin order) before compounding is enabled.
- **Consequence.** Until the super admin grants `AutoLpAdmin` to a keeper cap and the keeper supplies bounds derived from a trusted reference with outward rounding, auto-LP fees accumulate in vaults and are never reinvested. This is a liveness gap, not a security exposure, and it is outside the Move code; it belongs on the release checklist with the role grant, the keeper's bounds policy and a dry run of one compound on a real vault.

Checked and clean

- Role check order: version, live role, bound validity, pair proof (Cetus), pool match, spot price, then custody; the gates pin it.
- `sign_in` uses `type_name::with_defining_ids`, matching how the deployment record spells roles.
- Zero `lp_meme` cannot reach `sqrt_price_x64`'s division: `allocation::plan` requires `lp_meme_bps > 0` and the smallest atomic supply is `10^9`.
- Cetus `is_meme_coin_a` still proves `(CoinA, CoinB)` is exactly the sale pair before the pool match, so the bounds are always interpreted in the matched pool's coin order.
- `AutoLpReceipt` has no abilities; every `take_auto_lp` must be closed by `keep_auto_lp` in the same call.
- No `Move.lock`, manifest or snapshot change in #225; published bytecode is a function of the source diff above only.

Coverage

Files and functions read in full at `af0765da`: `cetus.move` (all), `bluefin.move` (all), `migrators/lib/errors.move`, `vault.move` (`new`, `share_with_position`, `position_mut`, `has_auto_lp_position`, `attach_auto_lp_position`, `auto_lp_position(_mut)`, `split_fees`, `assert_fee_split_ready`, `apply_fee_split`, `take_auto_lp`, `keep_auto_lp`, `take_buyback_quote`,

`burn_buyback`, `assert_position`, `route_fees`, `burn`), `holder_rewards::close_round` signature, `blast_acl::sign_in` and readers, `package_version::assert_not_paused`/`is_paused`, `package_admin::pause`/`clear_pause_bits`, `blast_domain.move`, `migration::sqrt_price_x64`, `migration::is_seedable_price`, `core/lib/constants.move` sqrt bounds, `launch::finalize`, `launch::migrate`, `launch::buy_from_curve`, `curve::cap_buy_quote_input`, `allocation::plan`, `blast_presale::assert_seedable_price`, the Cetus interface `pool.move`/`factory.move`/`pool_creator.move` signatures and abilities, the pinned Bluefin `pool.move` signatures and abilities, the Sui `transfer.rs` native, the migrators and launchpad source gates, ADR 0139 and the ADR 0137 amendment, the deployment record, and the GiveRep PDF.

Cross-package paths traced: venue entry → `blast_acl::sign_in` → `AutoLpAdmin` (core); venue entry → `vault::take_auto_lp`/`keep_auto_lp`/`auto_lp_position_mut`/`attach_auto_lp_position` → `assert_position` → venue key; venue `collect_fees` → `vault::split_fees` → `route_fees` → auto-LP balances; `launch::finalize` → `allocation` → `migration::is_seedable_price`; `launch::migrate` → `migration::new`/`vault_terms` → venue `migrate` → `vault::new` (ctx); `presale` lifecycle signatures → test callers.

Checks run (all pass):

Check	Result
`sui move test --path sui/launchpad --threads 1 -i 10000000000`	449 / 449
`sui move test --path sui/migrators --threads 1 -i 1000000000`	40 / 40
`sui move test --path sui/vault --threads 1 -i 1000000000`	127 / 127
`sui move test --path sui/presale --threads 1 -i 1000000000`	287 / 287
`sui move test --path sui/core --threads 1 -i 1000000000`	85 / 85
`cargo test --locked --test venue_fork -- --test-threads=1` (native mainnet-bytecode fork)	11 / 11 (306 s; includes `compounding_guards` on all three venue cases)
`python3 scripts/check_move_style.py`	240 modules hold
`python3 scripts/check_move_errors.py`	339 errors, 3 native oracles
`python3 scripts/gen_llms.py --check`	current
`bash scripts/test_admin_delay.sh --boundaries-only admin launchpad presale migrators`	pass
`sui/vault` and `sui/core` `check_source_boundaries.sh`	pass
`git diff af0765da 86ee8cf9 -- sui/`	empty

Coverage remaining incomplete:

- `blast_admin` and `blast_partners` Move suites and the other native targets (`presale_venue_fork`, `atomic_migration`, `bootstrap`) were not rerun; #225 does not change those packages' production code. GiveRep reports them passing at `af0765da`.
- The venue fork runs against the committed snapshot at checkpoint 339033808, not live mainnet; Cetus v15 / Bluefin v17 ABI drift since then is not established here.

- No on-chain bytecode comparison was performed; the record's `verify-source` success for each package is taken as the parity evidence.
- The keeper's bounds derivation and the SDK transaction builder for the new ABI do not exist yet and could not be reviewed.
- Economic simulation of a within-bounds sandwich around a compound was reasoned, not simulated; the loss scales with the square of the tolerated price deviation and is limited to the auto-LP balance, so it was not pursued further.

Cross-check against the GiveRep report

Read after the conclusions above. The report's targeted remediation review through `af0765da` agrees with this review on every point it covers:

- **LOW-02 resolved.** Same mechanism and same residual assumption (keeper-derived bounds in pool coin order, no on-chain oracle). The eleven native tests it cites are the ones rerun here.
- **LOW-03 documentation only.** Agreed; custody remains an upgrade trust boundary for the vault and migrators packages, which the record shows as compatible upgrade caps sealed in `PackageAdmin` with the 48-hour notice.
- **INFO-04 resolved.** Agreed, and this review adds that the checked amounts equal the migrated amounts, so the preflight is exact rather than approximate.
- **INFO-01, INFO-07, INFO-10, REP-01.** Fixture, tooling and vault-binding items; consistent with the diff.
- **Test counts.** GiveRep's Move counts for launchpad, migrators, vault, presale and core match this run exactly, as do the instruction limits needed.

Differences: GiveRep does not record F-1 (pause coverage of the new admin operation) or F-3 (no role granted, no keeper). GiveRep's LOW-04 and LOW-05 (permissionless presale settle/cancel, proposals collapsing notice to zero) are outside #225 and were not re-examined here.

Release blockers within #225's scope

None. The reviewed changes are correct as merged and deployed. Before the compounding keeper is switched on, treat F-3 as a gating checklist item (role grant, builder for the new ABI, bounds policy with outward rounding, one supervised compound), and decide F-1 (add the pause check in a first vault upgrade, or record revocation as the stop mechanism).

Questions for the broader seven-package audit or live verification

1. **Upgrade authority.** `admin`, `partners` and `core` retain raw compatible `UpgradeCap`s at the multisig by explicit exception, outside the 48-hour notice the four wrapped packages enforce. The ADR 0137 design calls those three immutable; the record says "pending final audit". That decision, not #225, bounds how permanent vault custody really is (GiveRep LOW-03).
2. **Emergency pause.** No `PauseAdmin<...>` role is granted for any package. After the planned unpause, only the super admin could grant one; confirm that is the intended incident posture.
3. **Deployment parity.** The record's `verify-source` results are the only parity evidence; an independent on-chain module digest comparison for the seven packages would close GiveRep's stated limitation.

4. **Live venue ABI.** Confirm Cetus and Bluefin have not upgraded the functions the venues call since snapshot 339033808 (`sui/migrators/scripts/check_mainnet_abi.mjs`).
5. **Keeper design.** Reference source, freshness, outward-rounded bound derivation in the pool's coin order, and key custody for the `AutoLpAdmin` cap; the contracts enforce none of these.
6. **Out of scope but open in GiveRep.** `blast_sui` and `boosts/aftermath_adapter` do not compile at the frozen revision (INFO-11/12); LOW-04 and LOW-05 are retained design decisions.